

Analisi della vulnerabilità Null Session e simulazione di attacco ARP Poisoning tramite Ettercap

Santi Lo Faro

Data: 21/05/2026

Introduzione

In questo laboratorio sono state analizzate due problematiche molto conosciute nel panorama della sicurezza informatica: la vulnerabilità Null Session nei sistemi Windows e gli attacchi ARP Poisoning utilizzati negli scenari Man-in-the-Middle (MITM).

L'obiettivo dell'attività è stato comprendere il funzionamento di queste vulnerabilità, identificare i sistemi potenzialmente esposti, analizzare le principali tecniche di mitigazione e osservare concretamente il comportamento di un attacco MITM all'interno di una rete locale.

La seconda parte del laboratorio è stata svolta in ambiente pratico utilizzando Kali Linux, Ettercap e Wireshark per simulare un attacco ARP Poisoning e intercettare traffico HTTP non cifrato. Tutte le attività sono state eseguite esclusivamente in ambiente controllato e a scopo didattico.

Analisi della vulnerabilità Null Session

La Null Session è una vulnerabilità storicamente presente nei sistemi Windows che permette a un utente remoto di stabilire una connessione verso un host senza fornire credenziali di autenticazione. Questo comportamento era legato principalmente ai servizi SMB e NetBIOS utilizzati da Windows per la condivisione di file, stampanti e risorse di rete.

In presenza di questa vulnerabilità, un attaccante può ottenere informazioni sensibili sul sistema bersaglio senza effettuare un login reale. Tra le informazioni recuperabili possono essere presenti nomi utenti, condivisioni di rete, informazioni di dominio e dettagli relativi alla configurazione del sistema operativo.

La vulnerabilità prende il nome di “Null Session” proprio perché la connessione viene effettuata utilizzando una sessione vuota, quindi senza username e password.

Durante l’analisi teorica è stato osservato come questa problematica abbia interessato principalmente:

- Windows NT
- Windows 2000
- Windows XP
- Windows Server 2003

Nelle versioni moderne di Windows il problema è stato in gran parte mitigato tramite aggiornamenti di sicurezza e modifiche alle policy SMB. Tuttavia, sistemi legacy ancora presenti in alcune infrastrutture aziendali possono risultare vulnerabili, soprattutto in ambienti in cui vengono mantenute configurazioni obsolete per compatibilità con vecchi software o dispositivi.

Dal punto di vista offensivo, la Null Session rappresenta una tecnica molto utile nelle prime fasi di un attacco informatico perché consente attività di enumerazione. L’enumerazione consiste nella raccolta di informazioni sul sistema bersaglio prima di tentare ulteriori compromissioni.

Tecniche di mitigazione della Null Session

Per ridurre il rischio associato a questa vulnerabilità sono state analizzate diverse tecniche di mitigazione.

Una delle soluzioni più drastiche consiste nel disabilitare completamente la condivisione file e stampanti nei sistemi Windows che non necessitano di tali servizi. Questa scelta elimina buona parte della superficie di attacco legata a SMB e NetBIOS, anche se in ambito aziendale non sempre è applicabile poiché molte infrastrutture dipendono dalla condivisione di rete.

Un'altra contromisura molto importante consiste nel disabilitare NetBIOS su TCP/IP. NetBIOS è uno dei protocolli storicamente associati alle Null Session e la sua rimozione riduce il numero di porte esposte verso la rete.

Durante l'analisi è stato inoltre approfondito il ruolo dei firewall. Il filtraggio del traffico di rete permette infatti di limitare le connessioni SMB provenienti da host non autorizzati e di bloccare le porte più utilizzate da questi protocolli, come:

- TCP 139
- TCP 445

Anche la disattivazione dell'account Guest rappresenta una best practice molto importante, poiché gli accessi anonimi o guest possono facilitare attività di enumerazione o accesso non autorizzato.

Una delle misure più efficaci rimane comunque il continuo aggiornamento del sistema operativo. Microsoft rilascia regolarmente patch di sicurezza che correggono vulnerabilità note e rafforzano le configurazioni predefinite dei sistemi Windows. Applicare semplici aggiornamenti può avere un effort relativamente basso per un'azienda, mentre la migrazione verso sistemi più moderni può comportare costi maggiori legati a configurazione, compatibilità software e aggiornamento hardware.

È stato inoltre analizzato il ruolo delle autorizzazioni di condivisione file. Limitare l'accesso esclusivamente agli utenti realmente autorizzati riduce notevolmente il rischio di accessi anonimi e rappresenta una best practice fondamentale in qualsiasi ambiente enterprise.

Infine, sono stati considerati software di sicurezza e sistemi di monitoraggio in grado di individuare:

- tentativi di enumerazione
- accessi SMB sospetti
- connessioni anomale
- attività non autorizzate sulla rete

Analisi dell'attacco ARP Poisoning

La seconda parte teorica del laboratorio è stata dedicata all'ARP Poisoning, una tecnica utilizzata negli attacchi Man-in-the-Middle per intercettare o manipolare il traffico di rete all'interno di una LAN.

Questo attacco sfrutta il protocollo ARP (Address Resolution Protocol), utilizzato dai dispositivi di rete per associare un indirizzo IP a un indirizzo MAC fisico.

Quando un host deve comunicare con un altro dispositivo nella rete locale, invia una richiesta ARP per conoscere il MAC address associato all'IP di destinazione. Il problema principale del protocollo ARP è che non prevede meccanismi di autenticazione, rendendo possibile l'invio di risposte ARP falsificate.

Durante un attacco ARP Poisoning, l'attaccante invia pacchetti ARP contraffatti dichiarando che il proprio MAC address corrisponde all'indirizzo IP del router o del gateway della rete. La vittima aggiorna quindi la propria cache ARP associando erroneamente il gateway al MAC address dell'attaccante.

In questo modo il traffico della vittima viene reindirizzato verso la macchina malevola prima di raggiungere la destinazione reale. Questo consente all'attaccante di:

- intercettare comunicazioni
- analizzare traffico di rete
- manipolare pacchetti
- rubare credenziali non cifrate
- effettuare attacchi MITM

L'attacco può essere eseguito esclusivamente all'interno di una rete locale, quindi richiede che attaccante e vittima si trovino nella stessa LAN.

Tecniche di mitigazione dell'ARP Poisoning

Per mitigare questo tipo di attacchi sono state analizzate diverse contromisure.

La protezione più importante consiste nell'utilizzo di protocolli cifrati come HTTPS, TLS, SSL o VPN. Anche se la cifratura non impedisce direttamente l'attacco ARP Poisoning, impedisce comunque all'attaccante di leggere il contenuto delle comunicazioni intercettate.

È stata inoltre approfondita la segmentazione della rete tramite switch Layer 3 e VLAN. Suddividere la rete in sottoreti riduce la capacità dell'attaccante di raggiungere tutti gli host della LAN e limita l'impatto di eventuali attacchi MITM.

Grande importanza è stata data anche al monitoraggio continuo del traffico di rete. Controllare variazioni anomale nelle tabelle ARP, indirizzi MAC duplicati o traffico sospetto permette di individuare rapidamente tentativi di spoofing.

Durante l'analisi sono stati citati strumenti specifici come:

- Arpwatch
- XArp
- Snort

Snort, in particolare, è un IDS (Intrusion Detection System) molto utilizzato nel monitoraggio del traffico di rete e nel rilevamento di comportamenti anomali associati agli attacchi ARP spoofing.

Anche i software antivirus e anti-malware moderni possono contribuire al rilevamento di attività sospette all'interno della rete locale.

Infine, è stato evidenziato come la formazione degli utenti rappresenti una componente fondamentale della sicurezza. Comprendere i rischi del traffico non cifrato e delle reti non sicure permette di ridurre notevolmente la probabilità di successo di questo tipo di attacchi.

Simulazione pratica di attacco MITM con Ettercap

Nella seconda parte del laboratorio è stata effettuata una simulazione pratica di attacco Man-in-the-Middle tramite Ettercap utilizzando Kali Linux.

Ettercap è uno strumento molto conosciuto nell'ambito del penetration testing e dell'analisi delle reti. Può essere utilizzato sia tramite riga di comando sia tramite interfaccia grafica e consente di effettuare:

- sniffing del traffico
- intercettazione comunicazioni
- attacchi MITM
- ARP spoofing
- analisi dei pacchetti

Dopo aver configurato Kali Linux, è stato avviato Ettercap selezionando l'interfaccia di rete corretta associata alla LAN utilizzata per il test.

Una volta aperto il programma, è stata eseguita una scansione degli host presenti nella rete tramite la funzione "Scan for Hosts". Questa operazione ha permesso di individuare i dispositivi attivi presenti nella LAN, inclusi:

- gateway della rete
- host vittima
- altri dispositivi collegati

Nel laboratorio sono stati selezionati come target:

- il gateway/router 192.168.1.1
- la macchina vittima 192.168.1.104

I due host sono stati inseriti rispettivamente come Target 1 e Target 2 all'interno di Ettercap.

Prima di avviare l'attacco è stata controllata la cache ARP della vittima tramite il comando:

```
arp -a
```

L'output mostrava la normale associazione tra l'indirizzo IP del gateway e il MAC address reale del router.

Successivamente, tramite la sezione MITM di Ettercap, è stato avviato l'attacco ARP Poisoning. Il programma ha iniziato a inviare pacchetti ARP falsificati sia verso la vittima sia verso il router, facendo credere a entrambi che la macchina Kali Linux fosse il dispositivo legittimo.

Dopo alcuni istanti è stata nuovamente analizzata la cache ARP della vittima ed è stato possibile osservare che l'indirizzo IP del gateway risultava ora associato al MAC address della macchina Kali Linux.

Questo comportamento conferma il successo dell'attacco MITM.

Analisi del traffico con Wireshark

Per osservare il traffico di rete generato durante l'attacco è stato utilizzato Wireshark.

Analizzando i pacchetti catturati risultavano chiaramente visibili:

- richieste ARP
- reply ARP contraffatte
- modifiche nelle associazioni IP-MAC
- traffico reindirizzato

La cattura dei pacchetti ha permesso di comprendere concretamente il funzionamento dell'ARP spoofing e il modo in cui l'attaccante altera il comportamento della rete locale.

Durante l'analisi era inoltre possibile osservare la continua trasmissione di pacchetti ARP falsificati da parte della macchina Kali Linux per mantenere attiva la compromissione della cache ARP della vittima.

Intercettazione delle credenziali HTTP

Per dimostrare l'impatto reale di un attacco MITM è stato utilizzato il sito vulnerabile:

- testphp.vulnweb.com

Il sito utilizza traffico HTTP non cifrato, rendendolo ideale per una dimostrazione didattica.

Una volta effettuato il login dalla macchina vittima, Ettercap è riuscito a intercettare:

- username
- password
- richieste HTTP

Le credenziali risultavano visibili in chiaro proprio perché il traffico HTTP non utilizza alcuna forma di cifratura.

Questo dimostra concretamente quanto sia pericoloso utilizzare protocolli non cifrati all'interno delle comunicazioni Web moderne.

Se il sito avesse utilizzato HTTPS con TLS correttamente configurato, l'attaccante avrebbe comunque potuto intercettare i pacchetti di rete, ma non leggere direttamente il contenuto delle credenziali.

Conclusione

Il laboratorio ha permesso di approfondire due problematiche molto importanti nel campo della sicurezza informatica: le vulnerabilità Null Session e gli attacchi ARP Poisoning.

L'analisi teorica ha evidenziato come sistemi legacy, configurazioni obsolete e protocolli non sicuri possano rappresentare un grave rischio per le infrastrutture aziendali moderne.

La parte pratica ha invece mostrato concretamente come un attaccante possa manipolare la cache ARP di una rete locale, posizionarsi come Man-in-the-Middle e intercettare traffico HTTP non cifrato ottenendo informazioni sensibili come username e password.